Budget Goat Privacy Policy

Effective date: 2026-04-18 **Last updated:** 2026-04-18

Budget Goat ("we," "our," "us") is a privacy-first personal budgeting iOS application operated by Saaketh Manepalli. This policy explains what information we collect, how we use it, and the choices you have.

1. TL;DR

- **Your financial transactions live on your iPhone, not on our servers.** We analyze them on-device.
- We never sell, rent, or share your financial data with advertisers or data brokers.
- We do not include any third-party analytics, advertising, or session-recording SDK in the app.
- You can disconnect any bank and delete all local data at any time from the Settings screen.
- We use Plaid Inc. ("Plaid") to connect to your financial institution. Your bank credentials are entered inside Plaid's interface and never pass through Budget Goat.

2. Information We Collect

2.1 Information stored only on your iPhone (we never see it)

- Transaction records (date, amount, merchant name, bank-provided description, category) imported via Plaid
- Account balances and account names
- Budgets, notes, flags, and category overrides you create
- Recurring-pattern detections generated on-device
- Cursors used to page through Plaid transaction updates

These are stored locally in an encrypted SwiftData database protected by iOS Data Protection (`NSFileProtectionComplete`) and in your iOS Keychain.

2.2 Information on our servers

- A pseudonymous user identifier we issue to you for authentication
- The Plaid `access_token` for each bank you link, encrypted at rest
- Metadata needed to proxy Plaid API calls (item IDs, institution IDs)
- Minimal server logs (IP, timestamp, HTTP method/path, status) retained for 14 days for abuse and outage diagnostics

2.3 Information we do **not** collect

- No contact list access
- No location data beyond merchant locations returned by Plaid (stored on-device only)
- No crash reports with user identifiers (we use Apple MetricKit, which does not include user content)
- No advertising identifiers (IDFA)

3. How We Use Information

- **To provide the app:** fetch your transactions from Plaid, authenticate your sessions, and keep your bank link valid.
- **To improve categorization:** optionally, for transactions where Plaid's category confidence is low, we send a PII-stripped payload to Anthropic's Claude API to produce a canonical merchant name and category. Before transmission, we remove user identifiers, round transaction amounts, and strip account-number patterns from the transaction description. See §6.
- **To respond to support requests** you initiate by email.

We do **not** use your data for advertising, profile enrichment sold to third parties, credit decisions, or training generalized machine-learning models.

4. Plaid

To link your bank account, we use Plaid, a regulated financial data aggregator. When you tap "Connect a Bank":

1. Plaid presents its own interface where you authenticate with your financial institution.
2. Plaid issues an access token that lets us retrieve transactions for the accounts you authorize.
3. Plaid's collection and use of your information is governed by the Plaid End User Privacy Policy.

You can revoke Plaid's access at any time either from inside Budget Goat (Settings → Unlink Bank) or from my.plaid.com.

5. Third-Party Services

The only third parties that receive any information about you are:

Service	Purpose	What we send
Plaid Inc.	Bank account linking and transaction aggregation	Per Plaid API requirements
Fly.io, Inc.	Hosting of our backend proxy (US region)	Inbound traffic; no persistent PII outside of your Plaid `access_token`
Anthropic PBC (Claude API)	Transaction categorization fallback when Plaid confidence is below 0.85	PII-scrubbed payload only: rounded amount, ISO date, currency, and name with account-number patterns removed. No user ID.
Apple Inc.	App distribution and crash aggregation via MetricKit	Anonymous diagnostic signals only

We do not integrate any advertising network, social network tracking pixel, or customer-data platform.

6. Privacy Protections Applied Before Any Cloud LLM Call

When a transaction requires categorization beyond Plaid's confidence floor, we send the following to Anthropic's Claude API via our backend proxy:

- A rotating opaque identifier (not your user ID, not the Plaid transaction ID)
- The merchant description **with account-number patterns regex-stripped**
- The transaction amount **rounded to the nearest dollar**
- The ISO-8601 date
- The ISO 4217 currency code

We do **not** send: your name, email, account balances, account IDs, account owner information, geographic location, IP address (beyond network-level transport), user preferences, or any other transactions.

7. Data Retention

Category	Retention

Transaction and account data on your device	Until you unlink the bank or uninstall the app
Plaid `access_token` on our servers	Until you unlink the bank or delete your account
Server access logs	14 days
Backups	Backed up access tokens are purged within 30 days of deletion

You may delete your account by emailing saaketh.manepalli@gmail.com or by using the in-app "Delete Account" action. We will purge server-side records within 30 days.

8. Security

- All network traffic is encrypted with TLS 1.2 or greater.
- Access tokens are encrypted at rest using AES-256-GCM envelope encryption, with a master key held in our hosting provider's secrets manager and per-item data keys derived via HKDF.
- The iOS app stores sensitive identifiers in the iOS Keychain with hardware-backed biometric access control (`kSecAttrAccessibleAfterFirstUnlockThisDeviceOnly` + `.biometryCurrentSet`).
- Device-bound ECDSA keys provisioned in the Secure Enclave sign each backend request, preventing session-token replay from a different device.
- The backend enforces least-privilege IAM on all cloud resources.
- We do not log request bodies or response payloads that contain financial data.
- See `docs/SECURITY.md` for our technical security overview.
- Security issues may be reported to saaketh.manepalli@gmail.com.

No system is perfectly secure; we cannot guarantee absolute security, but we work to minimize risk and blast radius.

9. Your Rights

Everyone:

- Unlink any bank at any time from Settings.
- Delete all local data by uninstalling the app.
- Request server-side account deletion by emailing saaketh.manepalli@gmail.com.
- Export your local data from Settings → Export (JSON).

California residents (CCPA / CPRA): You have the right to know what personal information we hold, to delete it, to correct inaccuracies, and to opt out of its "sale" or "sharing." We do not sell or share your personal information in the CCPA sense. To exercise rights, contact saaketh.manepalli@gmail.com.

EU/EEA/UK residents (GDPR): You have rights of access, rectification, erasure, restriction, portability, and objection. The legal basis for processing is (i) performance of a contract (you asked us to show you your finances) and (ii) your consent (for optional LLM categorization). Contact saaketh.manepalli@gmail.com.

10. Children

Budget Goat is not directed to children under 13, and we do not knowingly collect information from children under 13. Some jurisdictions (e.g., the EU) require parental consent below 16.

11. Changes to This Policy

We will post material changes in the app and update the "Last updated" date at the top. For changes that materially expand data use, we will request your consent.

12. Contact

Saaketh Manepalli Mailing address available upon written request to saaketh.manepalli@gmail.com saaketh.manepalli@gmail.com Security issues: saaketh.manepalli@gmail.com